信息安全测评与风险评估

8.5 编制风险评估报告



授课教师：张玉

目录

CONTENTS

01 案例导入—“一份没人看懂的报告”（10分钟）

02 学习目标

03 为什么要编制风险评估报告？（10分钟）

04 报告前准备——整合前序活动成果

案例导入——“一份没人看懂的报告”（10分钟）

引入问题

前4个活动做完，数据有了——怎么“写”成一份能让决策者真正看懂、能推动行动的报告？

案例回放

1986年1月28日，“挑战者号”航天飞机升空73秒后爆炸解体，7名宇航员遇难。直接原因是O型密封圈在低温下失效——而这一风险，工程师事前是知道的。

- 发射前夜，工程师提交数据分析、据理力争，但关键数据淹没在图表中，报告没有给出明确的“不可发射”结论
- 管理层按“数据不足以支持推迟”继续发射——73秒后机毁人亡；事后费曼用一块浸入冰水的O型圈讲清了几百页报告没讲明白的事

问题讨论

01 报告“写了”，为什么没人“看懂”？问题出在哪一环？

如果是你来写这份风险评估报告，你会把“低温失效风险”放在报告的哪个位置、用什么方式呈现？

学习目标

通过本课学习，你将能够：

理解	风险评估报告在评估工作中的核心地位与法律/管理价值
掌握	风险评估报告的规范格式与编制要求（符合GB/T 20984）
能够	整合前序活动成果，编制一份完整的风险评估报告
能够	撰写清晰、具体、可操作的整改建议
具备	风险评估报告撰写与交付的专业能力

为什么要编制风险评估报告？（10分钟）

风险评估报告是风险评估工作的“最终产品”——承载全部价值。

决策依据

为组织管理层提供安全风险全景图，支撑安全投资决策（受益方：管理层）

合规证据

《网络安全法》、等保2.0要求定期开展风险评估并形成报告（受益方：监管机构）

整改依据

为安全整改提供“路线图”和优先级指导（受益方：运维团队）

档案留存

作为组织的安全档案，支持历史追溯和趋势分析（受益方：组织全体）

GB/T 20984-2022 5.6要求： 记录风险评估过程的相关文档，应符合相关要求，确保文档发布前得到批准、版本可识别、分发受控。

报告前准备——整合前序活动成果

素材1：教师演示用——模拟数据.dc

在动手写报告之前，先确认“弹药”是否齐全。前序活动成果清单：

01

8.1 资产识别与CIA赋值

资产清单（含CIA赋值），用于报告第三章“资产识别”

02

8.2 威胁识别与赋值

威胁识别表，用于报告第四章“威胁识别”

03

8.3 脆弱性识别与赋值

脆弱性分析表，用于报告第五章“脆弱性识别”

04

8.4 风险计算

风险计算表（矩阵法/相乘法），用于报告第六章“风险分析”

教学提示：如果前序活动数据不完整，教师应提供一套完整的模拟数据（见素材1）。本课重点在于“编制报告”，而非“补做评估”。

风险评估报告的结构（GB/T 20984参考框架）

风险评估报告一般包含8个核心章节：



素材2：风险评估报告模板.docx

章节名称	核心内容
第一章 概述	评估背景、目的、范围、依据、方法
第二章 评估对象简介	系统概况、网络拓扑、部署情况
第三章 资产识别	资产清单、资产赋值、重要资产标注
第四章 威胁识别	威胁源识别、威胁频次分析
第五章 脆弱性识别	技术脆弱性、管理脆弱性
第六章 风险分析	风险计算方法、风险计算结果、风险分布
第七章 已有安全措施确认	现有安全措施有效性分析

风险评估报告格式要求

专业的格式，是专业报告的第一步。要素要求：

封面
报告名称、委托单位、评估机构、评估日期、版本号

著录项
评估人员名单（应亲笔签名或电子签章）

目录
自动生成的完整目录，含页码

正文
结构清晰，章节编号规范，图表编号

附件
评估计算过程、评估人员信息表、原始记录等

格式
统一字体（建议宋体/黑体）、统一字号、统一行间距

语言
客观、准确、专业、简洁——**不模糊、不夸张**

风险评估报告各章节详解（一）——概述

第一章“概述”应包含以下内容：

评估背景	**为什么要做评估？什么驱动了本次评估？** 示例：“为贯彻落实《网络安全法》及等保2.0要求，XX单位于2026年9月委托我机构对其核心业务系统开展信息安全风险评估。”
评估目的	**要达到什么目标？** 示例：“全面识别系统面临的安全风险，为安全整改和加固提供依据。”
评估范围	**评估了什么？覆盖了哪些系统/资产？** 示例：“本次评估覆盖XX系统生产环境，涉及服务器12台、网络设备6台、安全设备3台、应用系统2个。”
评估依据	**依据什么标准/法规？** 示例：GB/T 20984-2022、GB/T 22239-2019等
评估方法	**用什么方法评估的？** 示例：访谈、文档审查、工具扫描、人工核查等

风险评估报告各章节详解（二）——资产识别

资产清单的核心要求：完整、可追溯、有赋值依据。

资产清单

列出全部资产（硬件、软件、数据、服务、人员）

资产赋值

CIA三性赋值（1-5级），说明赋值依据

重要资产标注

明确标注关键资产（CIA总分≥12或单项≥4）

资产示例表格

资产编号	资产名称	类别	CIA	综合	关键
A01	核心业务数据库	数据	5/5/5	5	
A02	Web应用服务器	硬件/软件	4/3/4	4	
A03	办公终端	硬件	2/2/2	2	